

MITS 5600G- Case Study – Topic 13 - Colonial Pipeline Attack (2021)

Andrew D'souza & Avishkar Sharma

Ontario Tech University

Security Policies and Risk Management - MITS 5600G

1st Jun 2026

Executive Summary

The largest refined products pipeline in the United States, running 5,500 miles from Texas to New Jersey, is operated by Colonial Pipeline, and in May 2021, a ransom note left on its IT systems forced it to completely shut down its operational technology as well as its IT network. Colonial Pipeline moves roughly 45% of the fuel that is consumed on the East Coast, U.S., hence its shutdown created widespread panic and regional fuel shortages. To mitigate this shortage, the federal authorities took emergency measures.

The attack was carried out by DarkSide, a group running a ransomware-as-a-service model, who used a valid password for logging into a legacy VPN account that had remained open, without multi-factor authentication enabled. The company ended up paying a ransom of about 75 bitcoin, equivalent to approximately 4.4 million USD at the time of the attack. U.S. authorities later recovered 63.7 bitcoin, equivalent to approximately 2.3 million USD, from a DarkSide-linked wallet.

This report will evaluate the Colonial Pipeline Attack by elaborating on the background of the incident, technical analysis, policy, governance and risk analysis, incident response and recovery. This report will also discuss the lessons learned from this attack and will suggest recommendations using the cybersecurity policy and risk management concepts learned in this course.

1. Background of the Incident

1.1 Colonial Pipeline and its critical-infrastructure role

The Colonial Pipeline has a piping network covering over 5,500 miles and operates gasoline, diesel, jet fuel, and other refined products from Texas to New Jersey. In addition to Washington, D.C., the systems cover 13 states and major shares of fuel supply for airports, hospitals, emergency services, the military, and trucking fleets on the East Coast. The Colonial Pipeline carries nearly 45% of the fuel consumed on the U.S. East Coast. This makes the Colonial Pipeline a high value target for cyber attackers.

1.2 The attack and timeline

On the morning of 7 May 2021, a Colonial control-room employee found a ransom note on the company's business (IT) network. An operations supervisor was alerted, a stop-work order was issued, and by around 6:10 a.m. the entire operation technology and IT systems were shut down as a precaution.

Key events unfolded as follows:

May 7, Colonial Pipeline shut down its operations after detecting a ransomware attack.

May 8, the company paid a ransom of 75 bitcoin, equivalent to about \$4.4 million at that time.

May 9, U.S. government officials announced emergency measures to mitigate fuel supply shortages through transport and regulatory measures.

May 11, CISA and the FBI then issued a joint advisory about the DarkSide ransomware-as-a-service group.

May 12, Colonial began restarting its systems and operations in parts.

May 13, the company informed that the entire pipeline system was back online and fully operational.

Although the operational technology of the pipeline, which drives the fuel, was not reportedly compromised, it was shutdown as a precautionary measure. More particularly, this shutdown was implemented to deny any lateral movement possibilities within the OT and to maintain physical safety, during the investigation of this attack.

2. Technical Analysis

2.1 Initial access via a dormant legacy VPN

The attacker, DarkSide, a ransomware-as-a-service group that uses ransomware tools to exfiltrate data from its targets, used valid credentials, through a data leak (source not confirmed) of a legacy VPN account with no MFA authentication enabled, to gain remote access of the IT systems for Colonial Pipeline. Once the network was penetrated, the attackers executed stealth reconnaissance, meaning they identified the core systems in the network to escalate privilege. Before deploying the ransomware, DarkSide, extracted approximately 100 Gb of data from the Colonial network.

2.2 Double-extorted

In the case of Colonial Pipeline, the data from the IT systems was double-extorted, meaning that the data was accessed, then exfiltrated, followed by encryption, and lastly the attackers left a note demanding payment in exchange for a decryption key.

2.3 IT/OT dependency and the precautionary shutdown

Colonial authorities were unsure about the separation and dependence between their Operational Technology, which is responsible for moving the fuel, and their IT network. Hence, as a precaution, both were completely shut down.

2.4 Recovery limitations

Once Colonial paid the ransom, attackers provided a decryption key to assist with the recovery of the IT systems. The decryption key provided was unable to quickly or accurately recover the stolen data on its own, and therefore, internal data backups and restoration processes were used in addition to the key.

3. Policy, Governance and Risk Analysis

Policies

Mandatory, high-level rules that must be followed by everyone within an organization and are created by the respective top-level management.

- Authentication: MFA is a mandatory rule that should be enforced on all accounts. However, in the case of Colonial Pipeline, MFA is not enabled which caused this breach to occur.
- Access Management and Identity Lifecycle: There should be rules for governing how employees' accounts are created, maintained and deactivated whenever they are no longer in use. In the case of Colonial Pipeline, the account removal processes were inadequate to prevent this attack.
- Backup and Recovery:

There should be robust technical protocols and schedules for backing up data and testing backup restoration times. Luckily, in the case of Colonial, they had data backups that helped with data restoration; however, the time needed for recovery was not known.

Risk Analysis

The required assessment for systematic vulnerabilities, dependencies and infrastructure , in order to calculate what could go wrong.

- IT/OT segmentation: There should not be any dependency between IT systems and the Operational Technology so that any breach in one of these systems does not affect the other. This was not the case for Colonial, as both were shut down due to the dependency being unknown.
- Assets and Legacy System Management: There should be ageing and monitoring for active accounts , however in the case of Colonial , an active legacy VPN profile was working and unmonitored.

Governance

It is the practice of defining and implementing policies , frameworks and controls.

- Incident response: A document that is created during the planning stages which describes what to do when a crisis occurs. It is a response strategy. In the case of Colonial, although backup recovery was mentioned in the incident response document, the actual restoration time was unknown prior to the incident. After the attack, restoration time was found to be too long and would cause significant fuel interruptions, which forced the Colonial authorities to pay the ransom amount without consulting the federal authorities.
- Third-party and law enforcement engagement: Due to the immediate involvement of third-party teams, part of the ransom amount was recovered from an attacker-linked wallet.

4. Response and Recovery

The incident response document listed data backups as the primary recovery tool in case of a crisis. However, after the discovery of the ransom note, Colonial realised their backup data and files were disorganized, and it would take a long and undetermined amount of time to restore.

Next, Colonial moved at speed from identification to complete pipeline closure as a precaution, which took approximately one hour. The company engaged the FBI immediately and worked with CISA and specialist incident-response firms to consult on addressing the breach. The FBI's public stance against paying ransom to the attackers was not followed by Colonial's CEO, Joseph Blunt. After paying the ransom, the FBI were quietly able to track a part of the total ransom payment made in bitcoin by discovering a DarkSide-linked digital wallet. An amount of 63.7 Bitcoin , equivalent to about 84% of the total amount, was recovered, mainly due to quickly notifying the authorities after the discovery of the breach.

Once the decryption key was received from DarkSide following the ransom payment that was made, Colonial realised that decrypting the data using the decryption tool was extremely slow - due to the file structure as well being destroyed, and was not capable of accurately restoring all the encrypted data/structure. Hence the tool could not be relied on completely for the recovery process. Therefore, the Colonial's IT team and external incident responders – led by Mandiant, used a mix of traditional data backups and selective decryption using the key supplied by the attacker.

In addition , to using the tool as well as the data backups for the recovery process, Colonial's IT department built an isolated and secure network environment entirely cut off from the internet. This isolated environment was used to meticulously scan the restored backup image to trace any DarkSide infection or compromise remaining on the system. Furthermore, all the available credentials on the company's Active Directory were forced to reset passwords and add multi-factor authentication. Before going live, Colonial's IT team ensured that the operational technology, i.e., the pumping stations, was air-gapped from the IT network to prevent malware from spreading from

one section to another. This hybrid approach allowed Colonial to bring the pipeline back online within 5 days of the breach.

Colonial began the reintroduction process in stages of its pipeline operations on May 12, with the announcement for the full system restart on May 13. Marine shipments and imports would serve as alternative means of supply, with two federal government emergency declarations, transportation waivers, and routes arranged at that time. Although steps were taken to mitigate the fuel shortage, public anxiety combined with delayed communication caused massive panic buying which led to fuel shortages across the nation.

5. Lessons learned and Recommendations

5.1 Access Management and Authentication

There should be rules for governing how employees' accounts are created, maintained and deactivated whenever they are no longer in use. Furthermore, MFA is a mandatory rule that should be enforced on all accounts.

5.2 IT/OT segmentation

There should not be any dependency between IT systems and the Operational Technology so that any breach in one of these systems does not affect the other.

5.3 Third-party and law enforcement engagement

Due to the immediate involvement of third-party teams, part of the ransom amount was recovered from an attacker-linked wallet.

5.4 Drafting a Disaster Recovery Report

To prevent from such catastrophic shutdown, Colonial pipeline must integrate Recovery Point Objective and Recovery Time Objective metrics, which is the minimum amount of data that the organization is willing to lose before systems are recovered and the amount of time that the organization will need to restore operations during a crisis, respectively.

6. Conclusion

The Colonial Pipeline ransomware attack shows how one legacy remote-access account, left active and unprotected by MFA, can trigger a national-level disruption when it belongs to critical infrastructure. The event led to a multi-day pipeline shutdown, a multi-million-dollar ransom payment, emergency federal action, and lasting changes in U.S. pipeline cybersecurity policy. It also highlights the value of coordination with 3rd party authorities and the reality that preventive controls like retiring old VPN accounts and enforcing MFA are inexpensive compared to the cost of a major outage.

References

Carmakal, C. (2021, June 4). Colonial Pipeline hacked via inactive account without MFA. CRN. <https://www.crn.com/news/security/colonial-pipeline-hacked-via-inactive-account-without-mfa>

Georgetown Environmental Law Review. (2023). Cybersecurity policy responses to the Colonial Pipeline ransomware attack. Georgetown Environmental Law Review Blog. <https://www.law.georgetown.edu/environmental-law-review/blog/cybersecurity-policy-responses-to-the-colonial-pipeline-ransomware-attack/>

PBS NewsHour. (2021, May 10). ‘Panic buying’ is driving the fuel shortage after Colonial Pipeline hack, expert says [TV broadcast]. PBS. <https://www.pbs.org/newshour/show/panic-buying-is-driving-the-fuel-shortage-after-colonial-pipeline-hack-expert-says>

Reeder, J. R., & Hall, T. (2021). Cybersecurity’s pearl harbor moment. *The Cyber Defense Review*, 6(3), 15-40.

U.S. Department of Transportation. (2021, May 10). USDOT details ongoing efforts to help mitigate potential impacts of Colonial Pipeline disruption. <https://www.transportation.gov/briefing-room/usdot-details-ongoing-efforts-help-mitigate-potential-impacts-colonial-pipeline>